🌐 Chapter 8: Network Design & Security Architecture

CompTIA Security+ Study Slides

Walailak University — Assist. Prof. Dr. CJ

🎯 Learning Objectives

- Review network fundamentals and OSI model layers
- Understand network segmentation, VLANs, and subnetting
- Explain NAT, ACLs, and firewall placement
- Recognize secure network zones (DMZ, Intranet, Extranet)
- Describe NAC, VoIP, and remote access security principles

🧭 Introduction

Network design defines how systems communicate securely and efficiently.
Security architecture ensures that each network layer is protected from potential threats.

🎯 **Goal:** Create a resilient, segmented, and monitored network structure.

🧩 OSI Model Overview

Open Systems Interconnection (OSI) model describes communication between devices in 7 layers.

Layer	Name	Function	Examples
7	Application	User interaction	HTTP, SMTP, FTP
6	Presentation	Data formatting, encryption	SSL/TLS, JPEG
5	Session	Establish/terminate sessions	NetBIOS, RPC
4	Transport	Reliable delivery	TCP, UDP
3	Network	Logical addressing, routing	IP, ICMP
2	Data Link	MAC addressing, framing	Ethernet, ARP
1	Physical	Hardware transmission	Cables, Hubs

📶 Data Encapsulation and Flow

- Each layer adds its own **header/trailer** during transmission.
- Data units:
  - Layer 4 → Segments
  - Layer 3 → Packets
  - Layer 2 → Frames
  - Layer 1 → Bits

💡 *Understanding OSI layers is crucial for security monitoring and troubleshooting.*

🧱 Switches and Layer 2 Security

Switch: connects devices within the same LAN segment.

Common Attacks:

- **MAC Flooding:** overwhelms switch CAM table; acts as a hub.
- **MAC Spoofing:** impersonates another device on the network.

Mitigations:

- Port security: limit number of MAC addresses per port.
- Use **802.1X authentication**.
- Disable unused switch ports.

🚦 Routers and Layer 3 Security

Router: connects multiple networks and routes IP packets.

- Uses **Access Control Lists (ACLs)** to filter traffic.
- Supports **Network Address Translation (NAT)** and **Port Address Translation (PAT)**.
- Can segment traffic between **LAN**, **WAN**, and **DMZ**.

💡 *Routers form the backbone of perimeter defense.*

🔒 Access Control Lists (ACLs)

ACLs define **which traffic is allowed or denied** through a router or firewall.

Example Rule:

```
deny tcp any any eq 23      ! Block Telnet
permit tcp any any eq 80    ! Allow HTTP
```

Term	Meaning
Explicit Allow	Rule explicitly permits traffic
Explicit Deny	Rule explicitly blocks traffic
Implicit Deny	Default deny-all at end of ACL

🔄 Network Address Translation (NAT)

NAT: translates private IPs to public IPs for Internet communication.

Type	Description	Example
Static NAT	One-to-one mapping	10.0.0.5 ↔️ 203.0.113.5
Dynamic NAT	Pool of public IPs	10.0.0.0/24 ↔️ pool
PAT (NAT Overload)	Many-to-one using port mapping	Home routers, enterprise gateways

🎯 **Purpose:** hide internal addressing and conserve IPv4 space.

🧩 VLAN (Virtual Local Area Network)

Definition: logical segmentation of a network at Layer 2.

Benefits:

- Isolates traffic between departments
- Reduces broadcast domains
- Improves performance and security

Example:

VLAN	Department	Subnet
10	HR	10.10.10.0/24
20	Finance	10.10.20.0/24
30	IT	10.10.30.0/24

⚠️ VLAN Attacks & Mitigation

- **Switch Spoofing:** attacker pretends to be a switch to join trunk.
- **Double Tagging:** adds two VLAN tags to access restricted networks.

Prevention:

- Disable auto-trunking (DTP).
- Move unused ports out of the default VLAN.
- Implement VLAN ACLs (VACLs).

🧮 Subnetting and IP Design

Subnetting divides a network into smaller logical segments.

Benefits:

- Improves management and performance
- Supports network segmentation for security
- Enables granular access control

Example:

```
192.168.10.0/24 → 192.168.10.0/26, .64/26, .128/26, .192/26
```

💡 Smaller subnets = reduced broadcast domain.

🧱 Network Zones

Segmentation creates zones of trust within a network.

Zone	Description
Intranet	Internal trusted users
Extranet	Partner or vendor access
DMZ (Demilitarized Zone)	Hosts public-facing servers (web, mail)
Internet	Untrusted external network

🔥 Place **firewalls** between each zone to control access.

🛡️ Demilitarized Zone (DMZ)

Purpose: provide limited access to public services while isolating the internal LAN.

Example:

- Web server in DMZ accessible from Internet
- Database server remains in internal LAN
- Firewall restricts inbound/outbound traffic

💡 Use **dual firewalls** (external and internal) for stronger DMZ security.

🧰 Network Access Control (NAC)

Definition: system that enforces health and compliance checks before allowing device access.

Type	Description
Persistent Agent	Installed permanently on host
Non-Persistent Agent	Temporary or remote scan
802.1X	Port-based NAC standard for authentication

If a device fails checks → quarantine VLAN.

📡 Telephony & VoIP Security

VoIP (Voice over IP) transmits voice over data networks.

Risks:

- Eavesdropping
- SIP registration hijacking
- Denial of service (DoS)
- QoS degradation

Mitigation:

- Encrypt with **SRTP (Secure RTP)**
- Segment VoIP traffic on its own VLAN
- Apply firewall and QoS policies
- Use strong authentication for SIP endpoints

🧠 Defense in Depth for Network Design

Combine multiple layers of control for comprehensive protection.

- Firewalls at network boundaries
- IDS/IPS for threat detection
- Segmentation via VLANs and subnets
- NAC for endpoint control
- VPN for secure remote access
- Logging and SIEM for visibility

🎯 *Layered defense = resilient network.*

✅ Key Takeaways

- Understand OSI model and how attacks map to each layer
- Segment networks using VLANs, subnets, and DMZs
- Control access with ACLs and NAT
- Apply NAC and secure routing practices
- Design with defense-in-depth and least privilege principles

🏁 End of Chapter 8

Next: Chapter 9 — Perimeter & Firewall Security